

PS04 – Plan del Sistema de Gestion de Seguridad de la Informacion (SGSI)

ID Documento: GOYA-PS04-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-09-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto Criptografico / Sistema
Aprobacion	Pendiente	Gerente General

1.2 Distribucion

Este documento se clasifica como **Confidencial** y se distribuye al Oficial de Seguridad, Gerencia General, Administrador PKI, Administrador de RA, Personal Tecnico y Auditoria Interna. Cada receptor debe registrar acuse de recibo.

1.3 Relacion con EA-103 v2.1

Este documento cumple con el sub-proceso PS04 de la Guia de Acreditacion EA-103 v2.1 de la Entidad Acreditadora (Subsecretaria de Economia), seccion 4.11. Su dependencia directa es PS02 (Politica de Seguridad de la Informacion, GOYA-PS02-001).

Criterio EA-103 4.11	Referencia en este documento
1. Recursos y capacidad para implementar mecanismos de seguridad justificados	Seccion 6.1
2. Procedimientos alcanzan nivel de riesgo residual de PS01	Secciones 5.1, 7
3. Procedimientos alcanzan objetivos de seguridad de PS02	Seccion 5.2
4. Plan mantenible en el tiempo	Seccion 14
5. Objetivos de seguridad del CPS/CP alcanzados	Secciones 5.2, 8
6. Secciones ISO 27002 abordadas: organizacional (5), personas (6), fisico (7), tecnologico (8)	Seccion 8
7. Plan del ciclo de vida de gestion de claves	Seccion 9
8. Proteccion del repositorio publico de certificados	Seccion 10
9. Proteccion de informacion privada de registro	Seccion 11

1.4 Documentos relacionados

ID	Documento	Relacion
GOYA-PS01-001	Plan de Gestion de Riesgos y Amenazas	Riesgos y tratamiento que este SGSI implementa
GOYA-PS02-001	Politica de Seguridad de la Informacion	Politica y objetivos que este SGSI operacionaliza
GOYA-PS03-001	Plan de Continuidad del Negocio y Recuperacion de Desastres	Continuidad y procedimientos de emergencia referenciados
CPS v1.0.0	Certification Practice Statement (OID 1.3.6.1.4.1.99999.2.2)	Practicas de certificacion alineadas con el SGSI
GOYA-IRP-001	Plan de Respuesta a Incidentes (PS07)	Procedimientos de respuesta a incidentes de seguridad

2. Objetivo y Alcance

2.1 Objetivo

Definir el plan para implementar, operar, monitorear, revisar, mantener y mejorar el Sistema de Gestion de Seguridad de la Informacion (SGSI) de Goya Ledger SpA en su calidad de Prestador de Servicios de Certificacion (PSC) acreditado bajo la Ley

19.799. Este plan sigue la estructura de ISO/IEC 27001:2022 e incorpora los controles de ISO/IEC 27002:2022 y las directrices de implementacion de ISO/IEC 27003:2017.

2.2 Alcance del SGSI

El SGSI abarca la totalidad de los servicios de confianza, sistemas de soporte, personal e infraestructura involucrados en la operacion del PSC:

Servicio	Descripcion	Norma tecnica
Autoridad Certificadora (CA)	Emision, gestion y revocacion de certificados X.509 para FEA con ML-DSA-65 (FIPS 204)	Ley 19.799, DS 181, D.S. 24/2019
Autoridad de Sellado de Tiempo (TSA)	Sellos de tiempo calificados RFC 3161 con precision NTP verificada	RFC 3161, ETSI EN 319 422
Respondedor OCSP	Consultas de estado de certificados en tiempo real	RFC 6960, ETSI EN 319 411-2
Autoridad de Registro (RA)	Verificacion de identidad presencial y remota (Smart-ID, ClaveUnica)	DS 181 Art. 13, ETSI EN 319 411-1
Infraestructura blockchain BFT	Nodos Rust/Actix-Web 4, consenso HotStuff + DPoS, almacenamiento RocksDB	N/A (infraestructura interna)
Aplicacion desktop Tauri	Light client macOS para operaciones de firma	N/A (interfaz de usuario)

2.3 Ciclo PDCA

El SGSI opera bajo el ciclo de mejora continua Plan-Do-Check-Act conforme a ISO/IEC 27001:2022:

Fase	Clausula ISO 27001	Actividades principales	Frecuencia
Plan	4, 5, 6	Contexto, liderazgo, planificacion, evaluacion de riesgos, definicion de controles	Inicial, luego anual
Do	7, 8	Implementacion de controles, operacion del SGSI, gestion de recursos	Continua
Check	9	Monitoreo, medicion, auditoria interna, revision por la direccion	Semestral (auditoria), anual (revision)
Act	10	Tratamiento de no conformidades, acciones correctivas, mejora continua	Continua

2.4 Relacion con PS01, PS02 y PS03

- **PS01 (Gestion de Riesgos):** El registro de riesgos R-01 a R-35 de PS01 es la entrada principal para la planificacion del SGSI. Los controles seleccionados en la Declaracion de Aplicabilidad (seccion 8) tratan directamente los riesgos catalogados. El nivel de riesgo residual definido en PS01 seccion 7 es la meta que los controles del SGSI deben alcanzar.
 - **PS02 (Politica de Seguridad):** Los objetivos de seguridad OS-01 a OS-10 de PS02 seccion 5.1 son los objetivos estrategicos del SGSI. Cada control implementado se vincula a uno o mas objetivos de PS02.
 - **PS03 (Continuidad del Negocio):** Los procedimientos de continuidad y recuperacion de PS03 se integran como controles operativos del SGSI, particularmente para los controles A.5.29 y A.5.30. El procedimiento de compromiso de clave (PS03 seccion 6.3) es un control critico del SGSI.
-

3. Contexto de la Organizacion (ISO 27001 clausula 4)

3.1 Comprension de la organizacion y su contexto

3.1.1 Contexto externo

Factor	Descripcion	Impacto en el SGSI
Regulatorio chileno	Ley 19.799, DS 181, D.S. 24/2019, Ley 19.628, Ley 21.459	Define requisitos minimos de seguridad para acreditacion y operacion del PSC
Entidad Acreditadora	Subsecretaria de Economia, guia EA-103 v2.1	Evalua el SGSI como parte del proceso de acreditacion (PS04)
Amenazas cuanticas	NIST PQC estandares finalizados (FIPS 203, 204, 205), transicion cripto global	Justifica ML-DSA-65 como algoritmo de firma y la preparacion PQC
Marco EU	eIDAS 2.0, ETSI EN 319 401/411	Alinea requisitos para futura operacion como TSP europeo (entidad Estonia)
Panorama de amenazas	Ataques a PKI (DigiNotar, Comodo), amenazas a cadena de suministro	Define el perfil de amenazas del catalogo PS01 seccion 4
Mercado de firma electronica en Chile	Competidores establecidos (E-Sign, TOC), adopcion creciente de FEA	Exige niveles de seguridad competitivos para diferenciacion

3.1.2 Contexto interno

Factor	Descripcion	Impacto en el SGSI
Arquitectura tecnica	Blockchain BFT (Rust/Actix-Web 4), criptografia post-cuantica	Controles tecnologicos especificos para blockchain y PQC
Tamano de la organizacion	Startup en fase inicial, equipo reducido	Roles multiples por persona, necesidad de automatizacion de controles
Infraestructura cloud	Fly.io region IAD, sin datacenter propio	Controles fisicos delegados al proveedor, verificados via SOC 2
Madurez de seguridad	Controles tecnologicos avanzados (TLS 1.3, mTLS, ACL, PQC), controles organizacionales en desarrollo	Brecha entre madurez tecnica y madurez de procesos
Modelo de desarrollo	Codigo abierto con componentes propietarios de PKI	Gestion de vulnerabilidades incluye dependencias publicas

3.2 Partes interesadas y sus requisitos

Parte interesada	Requisitos de seguridad	Documento de referencia
Entidad Acreditadora (Subsecretaria de Economia)	Cumplimiento EA-103 v2.1, ISO 27001, auditorias periodicas	EA-103 v2.1, DS 181
Suscriptores (titulares de certificados FEA)	Proteccion de claves, disponibilidad de servicios OCSP/CRL, privacidad de datos personales	Ley 19.799, Ley 19.628, Acuerdo de Suscriptor
Terceros que confian (relying parties)	Integridad de certificados, disponibilidad de OCSP, precision de TSA	CPS, CP
Proveedor cloud (Fly.io)	Cumplimiento de SLA, aislamiento de cargas de trabajo	Contrato de servicio
Personal del PSC	Condiciones de trabajo seguras, formacion en seguridad	Contratos laborales, PE01
Regulador de datos personales (Servicio Nacional del Consumidor hasta implementacion de nueva autoridad)	Cumplimiento Ley 19.628	Ley 19.628

Parte interesada	Requisitos de seguridad	Documento de referencia
RIA Estonia (futuro)	Cumplimiento ETSI EN 319 401 para notificación como TSP europeo	ETSI EN 319 401, eIDAS 2.0

3.3 Límites del SGSI

El SGSI abarca:

- Todos los sistemas informáticos que soportan los servicios CA, TSA, OCSP y RA.
- La infraestructura de red, almacenamiento y procesamiento en Fly.io (region IAD).
- El código fuente del sistema (repositorio goya-ledger).
- Los datos de suscriptores y registros de auditoría.
- El personal con acceso a sistemas o datos del PSC.
- Los procesos de emisión, gestión y revocación de certificados.
- Los procesos de sellado de tiempo y consulta de estado.
- Los procesos de verificación de identidad (RA).

El SGSI no abarca:

- Los sistemas de los suscriptores fuera del entorno del PSC.
- La infraestructura física de los datacenters de Fly.io (cubierta por el SOC 2 del proveedor).
- Los sistemas de terceros proveedores de identidad (Smart-ID, ClaveUnica) más allá de la interfaz de integración.

4. Liderazgo y Compromiso (ISO 27001 cláusula 5)

4.1 Compromiso de la dirección

La Gerencia General de Goya Ledger SpA demuestra su compromiso con el SGSI mediante:

1. La aprobación de la Política de Seguridad (PS02, GOYA-PS02-001) y del presente plan del SGSI.
2. La asignación de recursos humanos, tecnológicos y financieros para la implementación y operación del SGSI conforme a la sección 6.1.
3. La designación formal del Oficial de Seguridad de la Información como responsable del SGSI.
4. La participación en las revisiones por la dirección (sección 12.3) con frecuencia anual.
5. La comunicación a todo el personal de la importancia del SGSI para la operación del PSC.
6. La declaración de la dirección firmada en PS02 sección 2.

4.2 Política de seguridad de la informacion

La politica de seguridad del SGSI es la documentada en PS02 (GOYA-PS02-001).
La politica:

- Es apropiada al proposito del PSC como prestador de servicios de confianza.
- Incluye los objetivos de seguridad OS-01 a OS-10 (PS02 seccion 5.1).
- Incluye el compromiso de cumplir los requisitos legales y regulatorios aplicables.
- Incluye el compromiso de mejora continua del SGSI.
- Esta disponible como informacion documentada de Uso Interno.
- Se comunica a todo el personal del PSC.
- Se revisa anualmente o ante cambios significativos.

4.3 Roles, responsabilidades y autoridades

Los roles y responsabilidades del SGSI se definen en PS02 seccion 7. La siguiente tabla resume las responsabilidades especificas del SGSI:

Rol	Responsabilidad en el SGSI	Referencia PS02
Gerencia General	Aprobacion del SGSI, asignacion de recursos, revision por la direccion	Seccion 7.1
Oficial de Seguridad	Implementacion y operacion del SGSI, coordinacion de auditorias, gestion de riesgos	Seccion 7.2
Administrador CA	Operacion de controles sobre emision/revocacion, custodia de claves CA intermedia	Seccion 7.3
Administrador RA	Operacion de controles sobre verificacion de identidad, proteccion de datos de registro	Seccion 7.4
Personal Tecnico	Implementacion de controles tecnologicos, monitoreo, respaldos	Seccion 7.5
Auditoria Interna	Verificacion de cumplimiento de controles del SGSI, auditorias planificadas	Seccion 7.6

5. Planificacion (ISO 27001 clausula 6)

5.1 Plan de tratamiento de riesgos

El plan de tratamiento de riesgos del SGSI se deriva directamente de PS01 (GOYA-PS01-001) seccion 7. Los controles seleccionados para tratar cada riesgo se documentan en la Declaracion de Aplicabilidad (seccion 8).

La siguiente tabla resume la relacion entre los riesgos de nivel Medio o superior de PS01 y los controles del SGSI:

Riesgo PS01	Nivel	Controles ISO 27002:2022 seleccionados	Riesgo residual meta
R-02: Robo de clave CA intermedia	Medio (10)	8.24, 8.2, 5.3	Bajo (4)
R-03: Intrusion a nodos BFT	Medio (12)	8.20, 8.5, 8.8	Bajo (6)
R-04: DDoS contra API Gateway	Medio (12)	8.26, 8.6	Bajo (6)
R-05: Emision no autorizada por administrador	Medio (10)	5.3, 8.15, 8.2	Bajo (4)
R-06: Certificado a identidad falsa	Alto (15)	5.17, 8.15, 6.1	Bajo (6)
R-07: Falla NTP en TSA	Medio (12)	8.17	Bajo (4)
R-09: Fork de cadena	Medio (8)	8.25, 8.29	Bajo (4)
R-10: HNDL sobre FES	Medio (12)	8.24	Bajo (4)
R-12: Fallo en transicion cripto	Medio (8)	8.32, 8.24	Bajo (4)
R-13: Vulnerabilidad en ML-DSA-65	Medio (10)	8.28, 8.8	Bajo (4)
R-14: Phishing contra operador	Medio (12)	6.3, 8.5	Bajo (4)
R-15: Compromiso de dependencia	Medio (8)	8.25, 5.21	Bajo (4)
R-17: Error de configuracion	Medio (9)	8.9	Bajo (3)
R-23: Explotacion de CVE	Medio (9)	8.8	Bajo (3)
R-25: Ataque Sybil	Medio (8)	8.5, 5.17	Bajo (4)
R-26: Exfiltracion por personal	Medio (8)	5.10, 6.2, 6.6	Bajo (4)
R-28: Error en verificacion RA	Medio (12)	5.17, 8.15	Bajo (4)
R-30: Agotamiento de almacenamiento	Medio (9)	8.6	Bajo (3)

Riesgo PS01	Nivel	Controles ISO 27002:2022 seleccionados	Riesgo residual meta
R-32: Bug en consenso o firma	Medio (10)	8.28, 8.25, 8.29	Bajo (4)
R-35: Violacion Ley 19.628	Medio (8)	5.34, 8.11	Bajo (4)

5.2 Objetivos de seguridad del SGSI

Los objetivos de seguridad del SGSI son los definidos en PS02 seccion 5.1. La siguiente tabla vincula cada objetivo con los controles del SGSI que contribuyen a su logro:

Objetivo PS02	Descripcion	Controles principales	KPI	Meta
OS-01	Proteger confidencialidad e integridad de claves privadas del PSC	8.24, 8.2, 5.3, 7.10	Incidentes de compromiso de clave	0/ano
OS-02	Disponibilidad de servicios CA, TSA, OCSP conforme a SLA	8.14, 8.6, 5.29, 5.30	Disponibilidad mensual	>= 99.5%
OS-03	Precision temporal del servicio TSA	8.17	Desviacion maxima respecto a UTC	<= 1 segundo
OS-04	Verificacion de identidad de solicitantes FEA	5.17, 6.1, 8.15	Tasa de error en verificacion	< 0.5%
OS-05	Integridad de registros de auditoria	5.33, 8.15, 8.13	Fallas en verificacion de cadena hash	0/ trimestre
OS-06	Proteccion de datos personales (Ley 19.628)	5.34, 8.11, 8.10, 8.24	Incidentes de fuga de datos	0/ano
OS-07	Resiliencia criptografica frente a amenazas cuanticas	8.24, 8.28, 8.8	Certificados FEA emitidos con ML-DSA-65	100%
OS-08	Prevencion de emision no autorizada	5.3, 8.15, 8.2	Emisiones fuera de flujo RA	0/ano
OS-09		5.21, 8.25, 8.8		0

Objetivo PS02	Descripcion	Controles principales	KPI	Meta
OS-10	Integridad de cadena de suministro de software		CVE criticas sin parche > 30 días	
	Capacidad de recuperacion ante desastres	5.29, 5.30, 8.13, 8.14	Tiempo de recuperacion en simulacro	RTO <= 4 horas

5.3 Planificacion de cambios

Los cambios al SGSI se gestionan mediante:

1. **Cambios planificados:** Resultantes de revisiones por la direccion, auditorias o evoluciones regulatorias. Se documentan en el plan de mejora continua (seccion 13) y se ejecutan conforme al proceso de gestion de cambios (control A.8.32).
2. **Cambios no planificados:** Resultantes de incidentes de seguridad, vulnerabilidades criticas o cambios regulatorios urgentes. Se ejecutan conforme al procedimiento de cambios de emergencia documentado en PS03.
3. **Registro:** Cada cambio al SGSI se registra con fecha, motivo, responsable, impacto evaluado y aprobacion.

6. Soporte (ISO 27001 clausula 7)

6.1 Recursos

6.1.1 Personal

Rol	Cantidad requerida	Estado actual	Plazo
Oficial de Seguridad de la Informacion	1 (tiempo completo)	Designado (dedicacion parcial)	2027-Q1: dedicacion completa
Administrador CA/PKI	1 (tiempo completo)	Designado	Operativo
Administrador RA	1 (tiempo parcial)	Designado	Operativo
Administrador de Sistemas	1 (tiempo completo)	Designado	Operativo
Arquitecto Criptografico / Sistema	1 (tiempo completo)	Designado	Operativo
Lider de Desarrollo	1 (tiempo completo)	Designado	Operativo
		Pendiente	2027-Q1

Rol	Cantidad requerida	Estado actual	Plazo
Auditor Interno	1 (tiempo parcial o contratado)		

6.1.2 Presupuesto

Partida	Descripcion	Estimacion anual (USD)	Estado
HSM	Adquisicion de HSM FIPS 140-3 Nivel 2+ para claves CA/TSA/OCSP	15.000-30.000	Planificado 2027-Q1
Infraestructura Fly.io	Nodos BFT produccion, volumenes persistentes, ancho de banda	6.000-12.000	Operativo
Auditoria externa	Auditoria anual de seguridad por firma independiente	10.000-20.000	Planificado 2027-Q2
Capacitacion	Formacion en seguridad para personal del PSC	3.000-5.000	Planificado 2027-Q1
Herramientas de seguridad	Escaneo de vulnerabilidades, monitoreo, gestion de logs	2.000-5.000	Parcial
Certificaciones profesionales	CISSP, CISM o equivalente para Oficial de Seguridad	3.000-5.000	Planificado 2027

6.1.3 Infraestructura

La infraestructura del SGSI se apoya en los activos catalogados en PS01 secciones 3.1 a 3.4. Los activos criticos para la operacion del SGSI son:

- Nodos BFT en Fly.io (AI-01): procesamiento de servicios CA, TSA, OCSP.
- Almacenamiento RocksDB (AI-02): persistencia de bloques, certificados, registros de auditoria.
- Red P2P (AI-03): comunicacion entre nodos con mTLS.
- API Gateway (AI-04): punto de entrada para servicios REST.
- Sistema de backup (AI-06): respaldos off-site de RocksDB.

6.2 Competencias

Rol	Competencias requeridas	Verificacion
Oficial de Seguridad	ISO 27001 Lead Implementer o equivalente, conocimiento de PKI, legislacion chilena de firma electronica	Certificacion profesional o experiencia demostrable ≥ 3 anos
Administrador CA/PKI	Operacion de CA, gestion de certificados X.509, procedimientos de ceremonia de claves	Capacitacion en operacion de PKI, experiencia ≥ 2 anos
Administrador RA	Verificacion de identidad, normativa DS 181 Art. 13, proteccion de datos personales	Capacitacion en procedimientos RA y Ley 19.628
Administrador de Sistemas	Administracion Linux, contenedores, redes, monitoreo, Rust	Experiencia demostrable ≥ 3 anos en administracion de sistemas
Arquitecto Criptografico	Criptografia aplicada (FIPS 204, Ed25519), protocolos de consenso BFT, Rust	Formacion en criptografia, experiencia demostrable en implementacion PQC
Auditor Interno	ISO 27001 Internal Auditor, metodologias de auditoria, evaluacion de controles	Certificacion ISO 27001 Internal Auditor o equivalente

Las brechas de competencia identificadas se abordan mediante el plan de capacitacion descrito en PE01.

6.3 Programa de concientizacion

Actividad	Audiencia	Frecuencia	Contenido
Induccion de seguridad	Personal nuevo	Al ingreso	Politica PS02, roles, manejo de informacion clasificada, reporte de incidentes
Capacitacion anual	Todo el personal	Anual	Amenazas actuales, ingenieria social, manejo de claves, privacidad de datos
Simulacros de phishing	Personal con acceso a sistemas	Semestral	Correos de phishing simulados, evaluacion de respuesta

Actividad	Audiencia	Frecuencia	Contenido
Capacitacion especializada CA	Operadores CA/RA	Anual	Procedimientos de ceremonia de claves, emision/revocacion, auditable
Actualizacion regulatoria	Oficial de Seguridad, Gerencia	Ante cambios regulatorios	Cambios en Ley 19.799, DS 181, EA-103, normativa ETSI

6.4 Plan de comunicacion

Evento	Emisor	Receptor	Metodo	Frecuencia
Estado de seguridad del SGSI	Oficial de Seguridad	Gerencia General	Informe escrito	Semestral
Resultados de auditoria interna	Auditor Interno	Gerencia, Oficial de Seguridad	Informe de auditoria	Semestral
Incidentes de seguridad P1/P2	Oficial de Seguridad	Gerencia General, Entidad Acreditadora	Telefono + informe escrito	Inmediata
Cambios en politica de seguridad	Oficial de Seguridad	Todo el personal	Correo + acuse de recibo	Ante cambios
Resultados de revision por la direccion	Gerencia General	Oficial de Seguridad, responsables de area	Acta de revision	Anual
Metricas de KPI de seguridad	Oficial de Seguridad	Gerencia General	Dashboard o informe	Mensual
Alertas de vulnerabilidades criticas	Lider Desarrollo	Oficial de Seguridad, Administrador Sistemas	Correo o mensaje directo	Inmediata

6.5 Informacion documentada

6.5.1 Documentacion requerida por ISO 27001

Clausula ISO 27001	Documento	ID
4.3	Alcance del SGSI	Este documento, seccion 3.3
5.2	Politica de seguridad	

Clausula ISO 27001	Documento	ID
		PS02 (GOYA- PS02-001)
6.1.2	Proceso de evaluacion de riesgos	PS01 (GOYA- PS01-001) secciones 2-5
6.1.3	Plan de tratamiento de riesgos	PS01 seccion 7, este documento seccion 5.1
6.1.3 d	Declaracion de Aplicabilidad	Este documento, seccion 8
6.2	Objetivos de seguridad	PS02 seccion 5.1, este documento seccion 5.2
7.2	Competencias	Este documento, seccion 6.2
8.1	Planificacion y control operacional	Este documento, seccion 7
8.2	Resultados de evaluacion de riesgos	PS01 seccion 6
8.3	Resultados de tratamiento de riesgos	PS01 seccion 7, este documento seccion 5.1
9.1	Resultados de monitoreo y medicion	Registros de metricas (seccion 12.1)
9.2	Programa de auditoria y resultados	Seccion 12.2
9.3	Resultados de revision por la direccion	Seccion 12.3
10.1	No conformidades y acciones correctivas	Seccion 13.1

6.5.2 Control de documentos

- Los documentos del SGSI se almacenan en el repositorio de la organizacion con control de versiones (git).
- Cada documento lleva: ID unico, version, fecha, autor, estado y clasificacion.
- Las versiones aprobadas se almacenan en docs/compliance/ del repositorio.
- Los cambios a documentos requieren revision y aprobacion conforme a la seccion 1.1.
- Los documentos obsoletos se retiran de circulacion y se archivan con marca de “Obsoleto”.
- La retencion minima de documentos del SGSI es de 6 anos conforme a DS 181.

7. Operacion (ISO 27001 clausula 8)

7.1 Planificacion y control operacional

La operacion del SGSI se estructura en procesos alineados con el ciclo PDCA y los servicios del PSC:

Proceso	Descripcion	Responsable	Controles asociados
Emision de certificados FEA	Recepcion de solicitud, verificacion RA, emision CA, entrega	Administrador RA + CA	5.17, 8.2, 8.15, 8.24
Revocacion de certificados	Solicitud de revocacion, verificacion, actualizacion CRL/OCSP	Administrador CA	5.17, 8.15
Sellado de tiempo	Recepcion de solicitud TSA, generacion de sello RFC 3161	Automatico (sistema)	8.17, 8.24
Consulta de estado OCSP	Recepcion de consulta, generacion de respuesta OCSP firmada	Automatico (sistema)	8.14, 8.24
Gestion de claves	Generacion, almacenamiento, rotacion, destruccion de claves	Administrador CA + Oficial de Seguridad	8.24, 5.3
Monitoreo de seguridad	Revision de logs, metricas, alertas	Personal Tecnico	8.15, 8.16
			8.8

Proceso	Descripcion	Responsable	Controles asociados
Gestion de vulnerabilidades	Deteccion, evaluacion, remediacion de vulnerabilidades	Lider Desarrollo	
Gestion de cambios	Evaluacion, aprobacion, implementacion de cambios	Personal Tecnico + Oficial de Seguridad	8.32
Respaldo y recuperacion	Ejecucion de respaldos, verificacion de integridad, restauracion	Personal Tecnico	8.13
Gestion de incidentes	Deteccion, clasificacion, respuesta, post-mortem	Oficial de Seguridad	5.24-5.28

7.2 Ejecucion de evaluacion de riesgos

La evaluacion de riesgos se ejecuta conforme a la metodologia documentada en PS01 secciones 2.1 a 2.5:

- **Periodicidad:** Anual (evaluacion completa) y ante cambios significativos (evaluacion focalizada).
- **Cambios significativos que disparan evaluacion:** Nuevo servicio, cambio de proveedor cloud, cambio de algoritmo criptografico, incidente P1/P2, cambio regulatorio.
- **Salida:** Actualizacion del registro de riesgos PS01 seccion 6 y del plan de tratamiento seccion 7.
- **Aprobacion:** Los riesgos residuales son aprobados por la Gerencia General.

7.3 Ejecucion de tratamiento de riesgos

Los controles seleccionados en la Declaracion de Aplicabilidad (seccion 8) se implementan conforme al cronograma:

Prioridad	Riesgos	Controles	Plazo
1 (inmediata)	R-06 (identidad falsa)	5.17, 8.15, 6.1	2027-Q1
2 (corto plazo)	R-02, R-03, R-04, R-05, R-14	8.24, 8.2, 8.20, 8.5, 5.3, 6.3	2027-Q1
3 (mediano plazo)	R-07, R-10, R-12, R-25, R-28	8.17, 8.24, 8.32, 5.17	2027-Q2
4 (continuo)	R-13, R-15, R-23, R-32	8.28, 8.8, 8.25, 5.21	Continuo

8. Declaracion de Aplicabilidad (Statement of Applicability)

La siguiente tabla lista los 93 controles de ISO/IEC 27002:2022 con su aplicabilidad al SGSI de Goya Ledger, justificacion, estado de implementacion y documento de referencia.

Estados de implementacion: - **Implementado:** Control operativo con evidencia disponible. - **Parcial:** Control parcialmente implementado, con brechas identificadas. - **Planificado:** Control no implementado, con plazo definido. - **N/A:** Control no aplicable con justificacion documentada.

8.1 Controles organizacionales (tema 5)

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
5.1	Políticas de seguridad de la informacion	Si	Requerido por ISO 27001 clausula 5.2 y EA-103 PS02	Implementado	PS02 (GOYA-PS02-001)
5.2	Roles y responsabilidades de seguridad de la informacion	Si	Segregacion de funciones critica para PSC (R-05)	Implementado	PS02 seccion 7
5.3	Segregacion de funciones	Si	Prevenir emision no autorizada de certificados (R-05, OS-08)	Parcial	PS02 seccion 6.6; ACL implementado, maker-checker pendiente
5.4	Responsabilidades de la direccion	Si	Compromiso gerencial requerido por ISO 27001 clausula 5.1	Implementado	PS02 seccion 2
5.5	Contacto con autoridades	Si	Obligatorio para PSC acreditado (Entidad Acreditadora, CSIRT)	Planificado	Directorio de contactos pendiente 2027-Q1
5.6	Contacto con grupos de interes especial	Si	Comunidades de seguridad PKI, ETSI, foros de criptografia PQC	Parcial	Participacion informal, sin proceso formal
5.7	Inteligencia de amenazas	Si	Monitoreo de amenazas a PKI y criptografia (R-13, R-23)	Parcial	cargo-audit continuo, monitoreo de CVE manual

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
5.8	Seguridad de la informacion en gestion de proyectos	Si	Cambios al PSC deben evaluar impacto en seguridad	Parcial	Proceso informal en desarrollo
5.9	Inventario de informacion y otros activos asociados	Si	Requerido para gestion de riesgos (PS01 seccion 3)	Implementado	PS01 secciones 3.1-3.4
5.10	Uso aceptable de informacion y otros activos asociados	Si	Prevencion de exfiltracion de datos (R-26)	Planificado	Politica de uso aceptable pendiente 2027-Q1
5.11	Devolucion de activos	Si	Recuperacion de accesos y activos al termino de empleo	Planificado	Procedimiento de desvinculacion pendiente 2027-Q1
5.12	Clasificacion de informacion	Si	Proteccion de claves y datos personales segun sensibilidad	Implementado	PS02 seccion 8.10 (4 niveles)
5.13	Etiquetado de informacion	Si	Identificacion de nivel de clasificacion en documentos	Parcial	Documentos PS01-PS04 etiquetados, sistema general pendiente
5.14	Transferencia de informacion	Si	Proteccion de datos en transito entre componentes del PSC	Implementado	TLS 1.3, mTLS entre nodos
5.15	Control de acceso	Si	Principio de minimo privilegio en todos los sistemas (PS02 seccion 8.1)	Implementado	ACL deny-by-default, enforce_acl
5.16	Gestion de identidades	Si	Identificacion unica de personal y sistemas del PSC	Parcial	DIDs implementados para sistemas, gestion de identidad de personal parcial
5.17	Informacion de autenticacion	Si	Verificacion de identidad de suscriptores	Parcial	Smart-ID operativo, ClaveUnica pendiente

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
			(R-06, R-28, OS-04)		
5.18	Derechos de acceso	Si	Gestion del ciclo de vida de accesos al PSC	Parcial	ACL implementado, proceso de revision trimestral pendiente
5.19	Seguridad de la informacion en relaciones con proveedores	Si	Proteccion de datos compartidos con Fly.io, proveedores de identidad	Planificado	Evaluacion de seguridad de proveedores pendiente 2027-Q1
5.20	Abordaje de seguridad en acuerdos con proveedores	Si	Clausulas de seguridad en contratos con proveedores cloud	Planificado	Revision de contratos pendiente 2027-Q1
5.21	Gestion de seguridad en la cadena de suministro TIC	Si	Seguridad de dependencias Rust y cadena de build (R-15, OS-09)	Parcial	cargo-audit y Cargo.lock con versiones fijadas, SBOM pendiente
5.22	Monitoreo, revision y gestion de cambios de proveedores	Si	Verificacion continua de seguridad de Fly.io y proveedores	Planificado	Proceso de revision de proveedores pendiente 2027-Q2
5.23	Seguridad de la informacion para uso de servicios cloud	Si	Proteccion de datos y servicios en Fly.io (R-03)	Parcial	TLS, aislamiento de red implementados, evaluacion formal de Fly.io SOC 2 pendiente
5.24	Planificacion y preparacion de gestion de incidentes	Si	Requerido para respuesta a compromiso de clave y otros incidentes	Implementado	PS07 (GOYA-IRP-001), PS03 seccion 6.3
5.25	Evaluacion y decision sobre eventos de seguridad	Si	Clasificacion P1-P4 de incidentes	Implementado	PS07, PS02 seccion 8.6
5.26	Respuesta a incidentes de seguridad de la informacion	Si	Procedimientos de respuesta ante compromiso de	Implementado	PS07, PS03 seccion 6.3

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
5.27	Aprendizaje de incidentes de seguridad de la informacion	Si	clave, intrusion, DDoS Post-mortem obligatorio para cada incidente	Implementado	PS07 (procedimiento post-mortem)
5.28	Recopilacion de evidencia	Si	Preservacion de evidencia para analisis forense y regulatorio	Parcial	Logs de auditoria append-only, procedimiento forense formal pendiente
5.29	Seguridad de la informacion durante disrupcion	Si	Continuidad de servicios criticos CA, TSA, OCSP (R-21, OS-10)	Implementado	PS03 (GOYA-PS03-001)
5.30	Preparacion de TIC para continuidad del negocio	Si	RTO 4h, RPO 1h para servicios criticos	Implementado	PS03 secciones 4-6
5.31	Requisitos legales, regulatorios y contractuales	Si	Cumplimiento Ley 19.799, DS 181, Ley 19.628, Ley 21.459	Implementado	PS02 seccion 4
5.32	Derechos de propiedad intelectual	Si	Proteccion de codigo fuente y licencias de dependencias	Parcial	Cargo.lock con licencias, politica formal de PI pendiente
5.33	Proteccion de registros	Si	Integridad de registros de auditoria (R-19, OS-05)	Implementado	Cadena hash SHA-256 append-only en RocksDB
5.34	Privacidad y proteccion de informacion de identificacion personal	Si	Proteccion de datos de suscriptores (R-35, OS-06, Ley 19.628)	Parcial	Aislamiento de datos, cifrado en transito; cifrado en reposo y politica de retencion pendientes
5.35	Revision independiente de seguridad de la informacion	Si	Auditoria externa anual requerida por EA-103	Planificado	Primera auditoria externa planificada 2027-Q2
5.36		Si		Parcial	

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
	Cumplimiento con politicas, reglas y estandares		Verificacion de cumplimiento de PS02		CI/CD verifica estandares tecnicos, auditoria interna de procesos pendiente
5.37	Procedimientos operacionales documentados	Si	Documentacion de procedimientos de operacion del PSC	Parcial	Procedimientos criticos documentados (CPS, PS01-PS04), procedimientos operativos detallados en desarrollo

8.2 Controles de personas (tema 6)

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
6.1	Seleccion	Si	Verificacion de antecedentes de personal con acceso a claves CA (R-06, OS-04)	Planificado	Procedimiento de seleccion pendiente 2027-Q1, ref PE01
6.2	Terminos y condiciones de empleo	Si	Obligaciones de seguridad en contratos laborales (R-26)	Planificado	Clausulas de seguridad en contratos pendientes 2027-Q1
6.3	Concientizacion, educacion y formacion en seguridad	Si	Prevencion de phishing y errores operativos (R-14, R-28)	Planificado	Programa de concientizacion pendiente 2027-Q1, ref seccion 6.3 de este documento
6.4	Proceso disciplinario	Si	Consecuencias por violaciones a la politica de seguridad	Planificado	Politica disciplinaria pendiente 2027-Q1
6.5	Responsabilidades despues del termino o cambio de empleo	Si	Revocacion de accesos y confidencialidad post-empleo (R-26, R-27)	Planificado	Procedimiento de desvinculacion pendiente 2027-Q1
6.6	Acuerdos de confidencialidad o no divulgacion	Si	Proteccion de informacion	Planificado	Modelo de NDA pendiente 2027-Q1

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
			critica del PSC (R-26)		
6.7	Trabajo remoto	Si	Personal opera remotamente, acceso a sistemas del PSC	Parcial	VPN y SSH con clave publica, politica formal de trabajo remoto pendiente
6.8	Reportes de eventos de seguridad de la informacion	Si	Canal de reporte para todo el personal	Parcial	Procedimiento informal existente, canal formal pendiente 2027-Q1

8.3 Controles fisicos (tema 7)

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
7.1	Perimetros de seguridad fisica	Si	Datacenter Fly.io tiene perimetro fisico controlado	Implementado	Verificado via SOC 2 de Fly.io (controles del proveedor)
7.2	Controles de entrada fisica	Si	Acceso controlado al datacenter	Implementado	Verificado via SOC 2 de Fly.io
7.3	Seguridad de oficinas, salas e instalaciones	Si	Oficinas del PSC (si aplica) requieren controles de acceso	Planificado	PSC opera remotamente; si se establecen oficinas fisicas, controles pendientes
7.4	Vigilancia de seguridad fisica	Si	Vigilancia del datacenter y areas de custodia de fragmentos M-of-N	Parcial	Datacenter: verificado via SOC 2 Fly.io; custodia M-of-N: controles en definicion
7.5	Proteccion contra amenazas fisicas y ambientales	Si	Proteccion contra incendio, inundacion, terremoto en datacenter (R-21, R-22)	Implementado	Verificado via SOC 2 de Fly.io
7.6	Trabajo en areas seguras	Si	Procedimientos para ceremonia de claves en area controlada	Planificado	Procedimiento de ceremonia de claves pendiente 2027-Q1

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
7.7	Escritorio limpio y pantalla limpia	Si	Prevencion de exposicion de informacion clasificada	Planificado	Politica pendiente 2027-Q1
7.8	Ubicacion y proteccion de equipos	Si	Proteccion de equipos de ceremonia de claves y administracion	Parcial	Equipos de ceremonia offline, procedimiento de almacenamiento en definicion
7.9	Seguridad de activos fuera de las instalaciones	Si	Fragmentos M-of-N almacenados en ubicaciones distribuidas	Parcial	Fragmentos distribuidos, procedimiento formal de custodia pendiente
7.10	Medios de almacenamiento	Si	Proteccion de medios que contienen claves o datos sensibles	Parcial	Zeroizacion implementada en software, destruccion de medios fisicos pendiente
7.11	Servicios de soporte	Si	Continuidad de energia y telecomunicaciones (R-31)	Implementado	Fly.io proporciona redundancia de energia y red
7.12	Seguridad del cableado	Si	Proteccion de cableado de red en datacenter	Implementado	Verificado via SOC 2 de Fly.io
7.13	Mantenimiento de equipos	Si	Mantenimiento preventivo de infraestructura	Implementado	Fly.io gestiona mantenimiento de hardware
7.14	Eliminacion o reutilizacion segura de equipos	Si	Destruccion de medios con claves o datos de suscriptores	Planificado	Procedimiento de destruccion segura pendiente 2027-Q1

8.4 Controles tecnologicos (tema 8)

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
8.1	Dispositivos de punto final de usuario	Si	Equipos de administracion del PSC y app desktop Tauri	Parcial	Tauri sandboxed, politica de endpoints de administracion pendiente
8.2		Si	Control de acceso	Implementado	

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
	Derechos de acceso privilegiado		administrativo a CA, nodos BFT (R-02, R-05, OS-01, OS-08)		ACL deny-by-default, enforce_acl, roles diferenciados
8.3	Restriccion de acceso a informacion	Si	Aislamiento de datos por servicio y rol	Implementado	Channels, ACL por endpoint
8.4	Acceso a codigo fuente	Si	Control de acceso al repositorio goya-ledger	Implementado	Control de acceso del repositorio Git
8.5	Autenticacion segura	Si	Autenticacion de operadores y nodos del PSC (R-03, R-14)	Implementado	mTLS para nodos, SSH con clave publica para administradores, JWT p API
8.6	Gestion de capacidad	Si	Prevencion de agotamiento de recursos (R-30, R-34)	Parcial	Monitoreo basico implementado, alertas automaticas pendientes
8.7	Proteccion contra software malicioso	Si	Prevencion de ejecucion de codigo malicioso en nodos	Implementado	Rust memory safety, Wasmer sandbox, sin ejecucion de codigo arbitrario
8.8	Gestion de vulnerabilidades tecnicas	Si	Deteccion y remediacion de CVE (R-13, R-23, OS-09)	Parcial	cargo-audit implementado, proceso formal con SLA de remediacion en definicion
8.9	Gestion de configuracion	Si	Control de configuracion de nodos y servicios (R-17)	Implementado	Variables de entorno documentadas, RUST_BC_ENV para produccion
8.10	Eliminacion de informacion	Si	Destruccion de datos personales al cumplir periodo de retencion (OS-06)	Planificado	Zeroizacion de claves implementada, eliminacion de datos de registro pendiente
8.11	Enmascaramiento de datos	Si	Proteccion de PII en logs y respuestas de API (R-35)	Parcial	Logs estructurados sin PII, enmascaramiento sistematico pendiente
8.12	Prevencion de fuga de datos	Si	Prevencion de exfiltracion de claves y datos de suscriptores (R-26)	Parcial	Aislamiento de red, ACL, monitoreo de exfiltracion pendiente

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
8.13	Respaldo de informacion	Si	Respaldos de RocksDB para recuperacion (R-16, OS-10)	Implementado	Checkpoints RocksDB, replicas BFT, respaldos off-site
8.14	Redundancia de instalaciones de procesamiento de informacion	Si	Disponibilidad de servicios criticos (OS-02)	Implementado	Consenso BFT tolera f fallas en 3f+1 nodos
8.15	Registro de eventos	Si	Trazabilidad de todas las operaciones del PSC (R-05, R-06, OS-05, OS-08)	Implementado	Cadena hash SHA-256 append-only, AuditAction por operacion
8.16	Monitoreo de actividades	Si	Deteccion de anomalias y eventos de seguridad (R-03)	Parcial	Health endpoint, metricas basicas; dashboards y alertas automaticas pendientes
8.17	Sincronizacion de relojes	Si	Precision temporal para TSA (R-07, OS-03)	Implementado	NtpTimeSource::validate multiples servidores NT tolerancia <= 1s
8.18	Uso de programas utilitarios privilegiados	Si	Control de herramientas con acceso privilegiado en nodos	Parcial	Acceso SSH restringido inventario de utilidades pendiente
8.19	Instalacion de software en sistemas en produccion	Si	Control de despliegues en nodos de produccion (R-18)	Implementado	CI/CD pipeline, revision de codigo, aprobacion antes de deploy
8.20	Seguridad de redes	Si	Proteccion de comunicaciones entre nodos BFT y API (R-03, R-29)	Implementado	mTLS obligatorio, TLS 1.3, verificacion de firmas en gossip
8.21	Seguridad de servicios de red	Si	Proteccion de servicios de red expuestos	Implementado	Fly.io edge proxying, rate limiting, CORS restricti
8.22	Segregacion de redes	Si	Separacion entre red P2P interna y API publica (R-03)	Implementado	Red BFT privada, solo API Gateway expuesto
8.23	Filtrado web	No	El PSC no proporciona acceso web a usuarios	N/A	Servidores sin navegador solo API

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
8.24	Uso de criptografia	Si	internos desde sus servidores Algoritmos criptograficos para firma, cifrado y hashing (R-01, R-02, R-10, OS-01, OS-07)	Implementado	ML-DSA-65 (FIPS 204 para FEA, Ed25519 para FES, SHA-256, TLS 1.3 pqc_crypto_module
8.25	Ciclo de vida de desarrollo seguro	Si	Desarrollo seguro del software del PSC (R-15, R-18, R-32, OS-09)	Implementado	CI/CD con fmt/clippy/test crypto_boundary test, revision de codigo
8.26	Requisitos de seguridad de aplicaciones	Si	Validacion de entradas, rate limiting, manejo de errores (R-04)	Implementado	Middleware de validacion rate limiting (RPS/RPM RPH), ApiResponse con trace ID
8.27	Principios de ingenieria y arquitectura de sistemas seguros	Si	Arquitectura de seguridad del PSC	Implementado	Defensa en profundidad modulo criptografico centralizado, crypto_boundary
8.28	Codificacion segura	Si	Practicas de codificacion segura en Rust (R-13, R-32)	Implementado	Rust memory safety, cli -D warnings, no unsafe modulo de firma
8.29	Pruebas de seguridad en desarrollo y aceptacion	Si	Verificacion de seguridad antes de despliegue (R-32)	Parcial	Tests unitarios y de integracion, pruebas de penetracion formales pendientes
8.30	Desarrollo externalizado	No	Todo el desarrollo es interno	N/A	Repositorio goya-ledger bajo control interno
8.31	Separacion de ambientes de desarrollo, prueba y produccion	Si	Aislamiento entre ambientes (R-18)	Implementado	RUST_BC_ENV, Docker Compose por ambiente
8.32	Gestion de cambios	Si	Control de cambios en produccion (R-17, R-18)	Parcial	CI/CD implementado, Change Advisory Board formal pendiente
8.33	Informacion de prueba	Si	Proteccion de datos usados en pruebas	Implementado	tempfile::TempDir para tests, datos sinteticos
8.34	Proteccion de sistemas de	Si	Proteccion del entorno de	Planificado	

Control	Nombre	Aplicable	Justificacion	Estado	Referencia
	informacion durante pruebas de auditoria		produccion durante auditorias		Procedimiento de auditoria con restricciones de acceso pendiente 2027-Q2

8.5 Resumen de la Declaracion de Aplicabilidad

Tema	Total	Aplicables	N/A	Implementado	Parcial	Planificado
Organizacional (5)	37	37	0	15	15	7
Personas (6)	8	8	0	0	2	6
Fisico (7)	14	14	0	6	4	4
Tecnologico (8)	34	32	2	21	9	2
Total	93	91	2	42	30	19

9. Gestion del Ciclo de Vida de Llaves Criptograficas

Esta seccion detalla el plan de gestion del ciclo de vida de las claves criptograficas del PSC, alineado con NIST SP 800-57 Parte 1. Este plan alimenta directamente a PS06 (Gestion de Claves Criptograficas).

9.1 Inventario de claves

ID	Clave	Algoritmo	Proposito	Nivel de proteccion	Referencia PS01
K-01	Clave privada CA raiz	ML-DSA-65 (FIPS 204)	Firma de certificado CA intermedia, firma de CRL raiz	Maxima (offline, M-of-N)	AC-01
K-02	Clave privada CA intermedia	ML-DSA-65 (FIPS 204)	Firma de certificados FEA de suscriptores, firma de CRL	Critica (HSM o memoria volatil)	AC-02
K-03	Clave privada TSA	ML-DSA-65 (FIPS 204)	Firma de sellos de tiempo RFC 3161	Critica (HSM o memoria volatil)	AC-03
K-04	Clave privada OCSP	ML-DSA-65 (FIPS 204)	Firma de respuestas OCSP	Critica (HSM o memoria volatil)	AC-04

ID	Clave	Algoritmo	Proposito	Nivel de proteccion	Referencia PS01
K-05	Claves de suscriptores FEA	ML-DSA-65 (FIPS 204)	Firma electronica avanzada	Alta (generadas en cliente)	AC-05
K-06	Claves de suscriptores FES	Ed25519 (FIPS 186-5)	Firma electronica simple	Media (generadas en cliente)	AC-05
K-07	Claves OID4VCI	ES256 (ECDSA P-256)	Firma de tokens OAuth 2.0 para emision de credenciales verificables	Alta	N/A
K-08	Claves TLS de nodos	ECDHE + certificado X.509	Autenticacion y cifrado de comunicaciones entre nodos	Alta	AI-03
K-09	Fragmentos M-of-N CA raiz	Shamir Secret Sharing	Respaldo y recuperacion de K-01	Maxima (distribuidos)	AC-01

9.2 Generacion de claves

9.2.1 CA raiz (K-01)

- **Ceremonia de claves:** Procedimiento documentado con testigos, en equipo air-gapped sin conexion a red.
- **Algoritmo:** ML-DSA-65 (FIPS 204, nivel de seguridad NIST 3).
- **Generador de numeros aleatorios:** CSPRNG del sistema operativo (/dev/urandom o equivalente), verificado por pqc_crypto_module.
- **Verificacion:** Generacion de firma de prueba y verificacion inmediata. Hash de clave publica registrado.
- **Frecuencia:** Una vez, con renovacion cada 10 anos o ante compromiso.
- **Participantes:** Minimo 3 personas: Oficial de Seguridad (supervisa), Administrador CA (ejecuta), Testigo independiente (documenta).

9.2.2 CA intermedia, TSA, OCSP (K-02, K-03, K-04)

- **Algoritmo:** ML-DSA-65 (FIPS 204).
- **Generacion:** En HSM certificado FIPS 140-3 Nivel 2+ (objetivo). Interim: generacion en memoria volatil del servidor con CSPRNG del sistema.
- **Verificacion:** Firma y verificacion de prueba, registro en log de auditoria.
- **Frecuencia:** Cada 3 anos o ante compromiso.
- **Participantes:** Administrador CA y Oficial de Seguridad.

9.2.3 Claves de suscriptores (K-05, K-06)

- **Algoritmo FEA:** ML-DSA-65 (FIPS 204). **FES:** Ed25519 (FIPS 186-5).

- **Generacion:** En el dispositivo del suscriptor (app Tauri o biblioteca cliente). El PSC no genera ni accede a claves privadas de suscriptores.
- **Verificacion:** El CSR (Certificate Signing Request) verifica la posesion de la clave privada antes de la emision del certificado.

9.2.4 Claves OID4VCI (K-07)

- **Algoritmo:** ES256 (ECDSA sobre P-256).
- **Generacion:** En el servidor del PSC, generada por `pqc_crypto_module`.
- **Frecuencia:** Cada 1 ano o ante compromiso.

9.3 Almacenamiento de claves

Clave	Almacenamiento actual	Almacenamiento objetivo	Plazo
K-01 (CA raiz)	Fragmentos M-of-N en medios offline distribuidos	Sin cambio (ya es el objetivo)	Implementado
K-02 (CA intermedia)	Memoria volatil del servidor (zeroizacion al terminar)	HSM FIPS 140-3 Nivel 2+	2027-Q1
K-03 (TSA)	Memoria volatil del servidor	HSM FIPS 140-3 Nivel 2+	2027-Q1
K-04 (OCSP)	Memoria volatil del servidor	HSM FIPS 140-3 Nivel 2+	2027-Q1
K-05, K-06 (suscriptores)	Dispositivo del suscriptor	Sin cambio (responsabilidad del suscriptor)	N/A
K-07 (OID4VCI)	Memoria volatil del servidor	HSM o almacenamiento cifrado	2027-Q2
K-08 (TLS nodos)	Volumenes persistentes Fly.io	Sin cambio, con rotacion automatica	Implementado

9.4 Respaldo de claves

9.4.1 Ceremonia M-of-N para CA raiz (K-01)

- **Esquema:** Shamir Secret Sharing con umbral M de N (configuracion recomendada: 3-of-5).
- **Procedimiento:**
 1. Generacion de la clave privada CA raiz en equipo air-gapped.
 2. Division de la clave en N fragmentos mediante Shamir Secret Sharing.
 3. Cada fragmento se almacena en un medio independiente (USB cifrado o papel laminado).
 4. Cada custodio recibe un fragmento y firma un acta de custodia.
 5. Los fragmentos se almacenan en ubicaciones fisicas independientes con control de acceso registrado.

- 6. La recombinacion requiere la presencia fisica de M custodios con sus fragmentos.
- **Verificacion:** Simulacro anual de recombinacion con fragmentos de prueba (no la clave real).
- **Referencia:** VAULT_RECOVERY_SECRET para el mecanismo tecnico.

9.4.2 Claves operativas (K-02, K-03, K-04)

- **Actual:** Sin respaldo separado (se regeneran si se pierden). El certificado de CA intermedia se regenera firmando con CA raiz.
- **Objetivo:** Respaldo cifrado en HSM secundario o medio offline cifrado.
- **Plazo:** 2027-Q1 (junto con migracion a HSM).

9.5 Rotacion de claves

Clave	Periodo de rotacion	Procedimiento
K-01 (CA raiz)	10 anos	Ceremonia de claves completa, emision de nueva CA intermedia
K-02 (CA intermedia)	3 anos	Generacion de nueva clave, firma por CA raiz, transicion gradual
K-03 (TSA)	3 anos	Generacion de nueva clave, emision de nuevo certificado TSA
K-04 (OCSP)	3 anos	Generacion de nueva clave, emision de nuevo certificado OCSP
K-07 (OID4VCI)	1 ano	Generacion de nueva clave, publicacion de nuevo JWK
K-08 (TLS nodos)	1 ano	Renovacion automatica de certificados TLS

9.6 Destruccion y zeroizacion de claves

Evento	Procedimiento	Verificacion
Rotacion de clave operativa	Zeroizacion de clave anterior en memoria (sobrescritura con ceros)	Log de auditoria registra evento de zeroizacion
Desmantelamiento de nodo	Zeroizacion de todas las claves en memoria + destruccion de volúmenes persistentes	Verificacion por Oficial de Seguridad
Compromiso de clave	Procedimiento de emergencia PS03 seccion 6.3: revocacion inmediata + destruccion de clave comprometida	Log de auditoria + informe a Entidad Acreditadora

Evento	Procedimiento	Verificacion
Fin de vida util de medio fisico (USB, papel M-of-N)	Destruccion fisica documentada (trituracion o incineracion)	Acta de destruccion firmada por dos personas
Zeroizacion en software	pqc_crypto_module implementa zeroize trait sobre buffers de clave	Verificado por test unitario

9.7 Compromiso de clave (procedimiento de emergencia)

En caso de compromiso confirmado o sospechado de cualquier clave del PSC, se ejecuta el procedimiento documentado en PS03 seccion 6.3, que incluye:

1. Confirmacion y clasificacion del compromiso.
2. Revocacion inmediata del certificado asociado.
3. Publicacion de CRL de emergencia y actualizacion del respondedor OCSP.
4. Notificacion a la Entidad Acreditadora conforme a DS 181.
5. Notificacion a suscriptores afectados.
6. Generacion de nueva clave y emision de nuevo certificado.
7. Post-mortem y acciones correctivas.

10. Proteccion del Repositorio Publico de Certificados

10.1 Descripcion del repositorio

El repositorio publico del PSC contiene:

- Certificados de CA raiz e intermedia.
- Certificados de suscriptores (parte publica).
- Listas de Revocacion de Certificados (CRL).
- Respuestas OCSP (bajo demanda).

El repositorio se implementa mediante:

- **Blockchain BFT:** Certificados y CRL almacenados en la cadena con integridad criptografica.
- **API REST:** Endpoints bajo /api/v1 para consulta de certificados y estado.
- **OCSP Responder:** Endpoint dedicado para consultas de estado en tiempo real (RFC 6960).

10.2 Controles de acceso

Operacion	Control	Implementacion
Lectura de certificados	Acceso publico	API REST sin autentificacion, solo lectura

Operacion	Control	Implementacion
Lectura de CRL	Acceso publico	Endpoint dedicado sin autenticacion
Consulta OCSP	Acceso publico	Respondedor OCSP sin autenticacion
Escritura de certificados	Solo CA autorizada	ACL deny-by-default, autenticacion de CA requerida
Publicacion de CRL	Solo CA autorizada	Firmada por clave CA, verificacion criptografica
Modificacion de certificados	Prohibida	Almacenamiento append-only en blockchain

10.3 Disponibilidad

Parametro	Valor	Mecanismo
SLA de disponibilidad	99% mensual	Consenso BFT con tolerancia a fallas (f en 3f+1)
RTO ante falla de nodo	< 30 minutos	Failover automatico por consenso BFT
Monitoreo	Continuo	Health endpoint con verificacion de dependencias
Proteccion DDoS	Rate limiting + Fly.io edge	RATE_LIMIT_RPS, RPM, RPH configurables

10.4 Integridad

Mecanismo	Descripcion
Firma criptografica de CRL	Cada CRL firmada con clave CA (ML-DSA-65), verificable por terceros
Firma de respuestas OCSP	Cada respuesta OCSP firmada con clave OCSP (ML-DSA-65)
Inmutabilidad blockchain	Certificados almacenados en bloques con hash SHA-256 encadenado
Consenso BFT	Tolerancia a nodos bizantinos previene alteracion unilateral
Verificacion de firma en gossip	Mensajes P2P firmados y verificados antes de procesamiento

10.5 Frecuencia de publicacion de CRL

Tipo	Frecuencia	Latencia maxima
CRL completa	Cada 24 horas	4 horas despues de la hora programada
	Cada 4 horas	

Tipo	Frecuencia	Latencia maxima
CRL delta (si aplica)		1 hora despues de la hora programada
CRL de emergencia (compromiso de clave)	Inmediata	1 hora despues de la declaracion de compromiso
Actualizacion OSCP	Tiempo real	Respuesta refleja estado actual del certificado

11. Proteccion de Informacion Privada de Registro

11.1 Clasificacion de datos de registro

Dato	Clasificacion	Ley 19.628	Periodo de retencion
Nombre completo del suscriptor	Confidencial	Dato personal	6 anos post-expiracion del certificado
RUT (Rol Unico Tributario)	Confidencial	Dato personal	6 anos post-expiracion del certificado
Correo electronico	Confidencial	Dato personal	6 anos post-expiracion del certificado
Datos de contacto (telefono, direccion)	Confidencial	Dato personal	6 anos post-expiracion del certificado
Evidencia de verificacion de identidad	Estrictamente Confidencial	Dato personal sensible	6 anos post-expiracion del certificado
Hashes de evidencia biometrica	Estrictamente Confidencial	Dato personal sensible	6 anos post-expiracion del certificado
CSR (Certificate Signing Request)	Uso Interno	No personal	6 anos post-expiracion del certificado
Registros de aprobacion/ rechazo RA	Confidencial	Contiene datos personales	6 anos post-expiracion del certificado

El periodo de retencion de 6 anos cumple con DS 181 para la conservacion de registros del PSC.

11.2 Controles de acceso

Rol	Datos accesibles	Operaciones permitidas
Administrador RA	Todos los datos de registro	Lectura, creacion, actualizacion de estado
Oficial de Seguridad	Registros de auditoria de RA, metadatos	Lectura
Administrador CA	CSR, estado de solicitud (sin datos personales)	Lectura
Auditor Interno	Todos los datos (para verificacion)	Lectura
Personal Tecnico	Ninguno (datos de registro)	Sin acceso
Suscriptor	Sus propios datos de registro	Lectura (derecho de acceso Ley 19.628)

El acceso se implementa mediante:

- ACL por endpoint (`enforce_acl`) con roles diferenciados.
- Autenticacion obligatoria para acceso a datos de registro.
- Registro de cada acceso en log de auditoria con identidad del accedente.

11.3 Cifrado

Capa	Mecanismo	Estado
En transito	TLS 1.3 obligatorio para todas las comunicaciones	Implementado
En reposo (base de datos)	Cifrado a nivel de campo para datos personales en RocksDB	Planificado (2027-Q1)
En reposo (volumenes)	Cifrado de volumenes Fly.io (proporcionado por el proveedor)	Implementado
En reposo (backups)	Cifrado de respaldos off-site	Planificado (2027-Q1)

11.4 Política de retencion y destruccion

1. Los datos de registro se conservan por 6 anos despues de la expiracion o revocacion del certificado asociado.
2. Al cumplirse el periodo de retencion, los datos se destruyen mediante:
 - Eliminacion segura de registros en RocksDB (borrado + compactacion).
 - Eliminacion de respaldos que contengan los datos.
 - Registro del evento de destruccion en el log de auditoria.
3. Un proceso automatizado verifica mensualmente los registros que han cumplido su periodo de retencion.

4. La destruccion se ejecuta en lotes trimestrales, verificada por el Oficial de Seguridad.

11.5 Cumplimiento con Ley 19.628

Requisito Ley 19.628	Implementacion
Consentimiento del titular	Consentimiento informado en el Acuerdo de Suscriptor, previo a la recoleccion
Finalidad determinada	Datos recolectados exclusivamente para verificacion de identidad y emision de certificados
Proporcionalidad	Solo se recolectan datos necesarios para la verificacion de identidad conforme a DS 181
Seguridad	Controles de acceso, cifrado, log de auditoria descritos en secciones 11.2-11.3
Derecho de acceso	Suscriptores pueden solicitar acceso a sus datos de registro via API autenticada
Derecho de rectificacion	Suscriptores pueden solicitar correccion de datos erroneos (requiere nueva verificacion RA)
Derecho de cancelacion	Datos se eliminan al cumplir periodo de retencion legal; eliminacion anticipada previa autorizacion
Comunicacion a terceros	Datos de registro no se comparten con terceros, excepto por requerimiento judicial o de la Entidad Acreditadora

12. Evaluacion del Desempeno (ISO 27001 clausula 9)

12.1 Monitoreo y medicion

Metrica	Fuente	Frecuencia	Responsable	Umbral de alerta
Disponibilidad de servicios CA, TSA,	Health endpoint, monitoreo externo	Continua	Personal Tecnico	< 99.5% mensual

Metrica	Fuente	Frecuencia	Responsable	Umbral de alerta
OCSF (OS-02)				
Desviacion temporal TSA vs UTC (OS-03)	NtpTimeSource::validate()	Cada solicitud TSA	Automatico	> 500ms
Incidentes de compromiso de clave (OS-01)	Registro de incidentes	Continua	Oficial de Seguridad	Cualquier incidente
Emisiones fuera de flujo RA (OS-08)	Log de auditoria, revision cruzada	Semanal	Administrador RA	Cualquier emision
CVE criticas sin parche > 30 dias (OS-09)	cargo-audit	Semanal	Lider Desarrollo	Cualquier CVE
Integridad de cadena hash de auditoria (OS-05)	Verificacion automatica	Diaria	Automatico	Cualquier falla
Tasa de error en verificacion de identidad (OS-04)	Revision cruzada de aprobaciones RA	Mensual	Administrador RA	> 0.5%
Porcentaje de FEA con ML-DSA-65 (OS-07)	Registro de certificados emitidos	Mensual	Administrador CA	< 100%
Tiempo de recuperacion en simulacro (OS-10)	Resultados de simulacro	Semestral	Oficial de Seguridad	> 4 horas
Fuga de datos personales (OS-06)	Registro de incidentes	Continua	Oficial de Seguridad	Cualquier incidente

12.2 Programa de auditoria interna

Elemento	Descripcion
Frecuencia	Semestral
Alcance	Todos los controles aplicables de la Declaracion de Aplicabilidad (seccion 8)
Auditor	

Elemento	Descripcion
	Auditor interno calificado (ISO 27001 Internal Auditor) o consultor externo independiente
Independencia	El auditor no participa en la operacion de los procesos auditados
Metodologia	Revision documental + evidencia tecnica + entrevistas + pruebas de control
Salida	Informe de auditoria con hallazgos clasificados (no conformidad mayor, no conformidad menor, observacion, oportunidad de mejora)
Seguimiento	Acciones correctivas con plazos definidos, verificacion de cierre en auditoria siguiente
Reporte	Al Oficial de Seguridad y Gerencia General

Calendario de auditoria primer ciclo:

Periodo	Foco de auditoria	Controles auditados
2027-Q1	Controles criticos de PKI y gestion de claves	8.24, 8.2, 5.3, 8.15, 5.17
2027-Q2	Controles organizacionales y de personas	5.1-5.14, 6.1-6.8
2027-Q3	Controles tecnologicos y de operaciones	8.5-8.9, 8.13, 8.16-8.17, 8.25, 8.28, 8.31-8.32
2027-Q4	Controles fisicos, proveedores y cumplimiento	7.1-7.14, 5.19-5.23, 5.31-5.36

12.3 Revision por la direccion

La revision por la direccion se ejecuta anualmente (o ante cambios significativos) con la siguiente agenda:

Entradas de la revision:

1. Estado de acciones de revisiones anteriores.
2. Cambios en contexto externo e interno relevantes al SGSI.
3. Resultados de monitoreo y medicion de KPIs (seccion 12.1).
4. Resultados de auditorias internas y externas.
5. Estado del tratamiento de riesgos (PS01).
6. Oportunidades de mejora continua.
7. Estado de no conformidades y acciones correctivas.

Salidas de la revision:

1. Decisiones sobre cambios al SGSI (politica, objetivos, controles).
2. Asignacion o reasignacion de recursos.
3. Aprobacion de nivel de riesgo residual actualizado.
4. Calendario de acciones para el proximo periodo.

Registro: Acta de revision firmada por el Gerente General, distribuida a los participantes.

13. Mejora Continua (ISO 27001 clausula 10)

13.1 No conformidad y accion correctiva

El proceso de gestion de no conformidades sigue estos pasos:

1. **Identificacion:** No conformidades detectadas mediante auditorias internas, revision por la direccion, incidentes de seguridad, monitoreo de KPIs, o reportes del personal.
2. **Registro:** Cada no conformidad se registra con: ID unico, fecha de deteccion, descripcion, control afectado, clasificacion (mayor/menor), fuente de deteccion.
3. **Reaccion inmediata:** Contener el impacto y corregir las consecuencias inmediatas.
4. **Analisis de causa raiz:** Investigar la causa subyacente para prevenir recurrencia.
5. **Accion correctiva:** Definir e implementar acciones que eliminen la causa raiz.
6. **Verificacion de eficacia:** Verificar que la accion correctiva elimino la no conformidad y no introdujo nuevos riesgos.
7. **Cierre:** Documentar el cierre con evidencia de verificacion.

Plazos:

Clasificacion	Accion correctiva	Verificacion
No conformidad mayor	30 dias	60 dias
No conformidad menor	90 dias	120 dias
Observacion	180 dias	Proxima auditoria

13.2 Proceso de mejora continua

La mejora continua del SGSI se alimenta de:

Fuente	Tipo de mejora	Frecuencia
Resultados de auditoria interna	Correcciones y mejoras de controles	Semestral
Revision por la direccion	Mejoras estrategicas al SGSI	Anual
Post-mortem de incidentes	Lecciones aprendidas, mejoras de procedimientos	Ante cada incidente
Evaluacion de riesgos	Nuevos controles o ajuste de controles existentes	Anual
Cambios tecnologicos	Adopcion de nuevas tecnologias de seguridad	Continua Ante cambios

Fuente	Tipo de mejora	Frecuencia
Cambios regulatorios	Adecuacion de controles a nuevos requisitos	Anual
Benchmarks del sector	Adopcion de mejores practicas de la industria PKI	

14. Mantenibilidad del Plan

14.1 Ciclo de revision

Tipo de revision	Frecuencia	Alcance	Responsable
Revision programada	Anual	Documento completo, Declaracion de Aplicabilidad, estado de controles	Oficial de Seguridad
Revision focalizada	Ante evento disparador	Secciones afectadas por el evento	Oficial de Seguridad
Actualizacion de estado	Trimestral	Estado de implementacion de controles en Declaracion de Aplicabilidad	Oficial de Seguridad

14.2 Eventos disparadores de revision

Evento	Seccion(es) afectada(s)	Plazo para revision
Nuevo riesgo identificado o cambio en nivel de riesgo existente	5.1, 8	30 dias
Incidente de seguridad P1 o P2	7, 8, 9, 10, 11	15 dias
Cambio en legislacion o regulacion (Ley 19.799, DS 181, EA-103)	2, 3, 5, 8	60 dias
Incorporacion o desvinculacion	4.3, 6.1, 6.2	30 dias

Evento	Seccion(es) afectada(s)	Plazo para revision
de personal clave		
Nuevo servicio o cambio significativo en servicio existente	2.2, 3, 7, 8	30 dias
Cambio de proveedor cloud o infraestructura	3, 7, 8 (controles fisicos y tecnologicos)	30 dias
Cambio de algoritmo criptografico	9	15 dias
Resultado de auditoria externa con hallazgos mayores	Secciones indicadas en hallazgos	30 dias
Cambio en amenazas cuanticas (nuevo algoritmo, nueva capacidad)	5.1, 8 (8.24), 9	30 dias

14.3 Control de versiones

- Cada version del documento se identifica con numero de version (major.minor) y fecha.
- Los cambios se registran en la tabla de control de cambios del encabezado.
- Las versiones aprobadas se almacenan en docs/compliance/PS04-ISMS-PLAN.md del repositorio con historial git.
- Las versiones anteriores se retienen por 6 anos.

15. Referencias

Referencia	Titulo
Ley 19.799 (2002)	Sobre documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
D.S. N 24/2019	Norma tecnica para prestadores de servicios de

Referencia	Titulo
	certificacion de firma electronica avanzada
Ley 19.628 (1999)	Sobre proteccion de la vida privada
Ley 21.459 (2022)	Establece normas sobre delitos informaticos
EA-103 v2.1	Guia de acreditacion de prestadores de servicios de certificacion
ISO/IEC 27001:2022	Information security, cybersecurity and privacy protection – Information security management systems – Requirements
ISO/IEC 27002:2022	Information security, cybersecurity and privacy protection – Information security controls
ISO/IEC 27003:2017	Information technology – Security techniques – Information security management systems – Guidance
ISO/IEC 27005:2022	Information security, cybersecurity and privacy protection – Guidance on managing information security risks
NIST SP 800-57 Parte 1 Rev. 5	Recommendation for Key Management: Part 1 – General
NIST FIPS 204 (2024)	Module-Lattice-Based Digital Signature Standard
NIST FIPS 186-5 (2023)	Digital Signature Standard
ETSI EN 319 401	General Policy Requirements for Trust Service Providers
ETSI EN 319 411-1	Policy and security requirements for Trust Service Providers issuing certificates – Part 1: General requirements
ETSI EN 319 411-2	Policy and security requirements for Trust Service Providers issuing certificates – Part 2: Requirements for trust service providers issuing EU qualified certificates
ETSI EN 319 421	Policy and Security Requirements for Trust Service Providers issuing Time-Stamps

Referencia	Titulo
ETSI TS 102 042	Policy requirements for certification authorities issuing public key certificates
RFC 3161	Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP)
RFC 3647	Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework
RFC 6960	X.509 Internet Public Key Infrastructure Online Certificate Status Protocol – OCSP
GOYA-PS01-001	Plan de Gestion de Riesgos y Amenazas
GOYA-PS02-001	Politica de Seguridad de la Informacion
GOYA-PS03-001	Plan de Continuidad del Negocio y Recuperacion de Desastres
GOYA-IRP-001	Plan de Respuesta a Incidentes (PS07)
CPS v1.0.0	Certification Practice Statement de Goya Ledger (OID 1.3.6.1.4.1.99999.2.2)